SOLSTICE HEALTH ANALYTICS

Building a Complete Policy Framework

GRC Portfolio Project

A policy framework architecture assessment for a growing health analytics company handling sensitive patient wellness data, cloud-hosted services, wearable data, and telehealth integrations.

Assessment focus

- Policy hierarchy and foundational policies
- Advanced policies for remote access and mobile devices
- Change Management Policy purpose, scope, and key statements
- Approval ownership, review cadence, and implementation governance

Case study: 180 employees across two offices, with a remote-first workforce

1. Executive Summary

Solstice Health Analytics has grown to approximately 180 employees across two offices, uses Azure-hosted patient wellness data, ingests wearable-device data, works with telehealth partners, and has a remote-first workforce. The case study states that the company has almost no formal policies. This creates inconsistent security practices, unclear ownership of information assets, and increased governance, security, and compliance risk.

The submitted work selected four foundational policies: Information Security, Access Control, Data Classification, and Acceptable Use. It also selected two advanced policies: Mobile Device and Remote Access/VPN. These are reasonable starting choices for the scenario. The main corrections are to clarify the policy hierarchy, distinguish a policy from its supporting standards and procedures, define realistic approval and review ownership, and replace operational instructions that do not belong in a Change Management Policy.

Primary recommendation: Establish a board-approved Information Security Policy supported by topic-specific policies, standards, procedures, named owners, and a documented review cycle. The Change Management Policy should define how changes are requested, assessed, approved, implemented, and reviewed, rather than changing all employees' reporting lines or introducing office attendance schedules.

2. Organization and Scope

The project describes three key business areas: Product & Engineering, Clinical Partnerships, and People & Operations. The company operates a health analytics platform, shares data with clinical partners, manages employee and contractor access, and uses cloud services and wearable-device data.

The policy framework should apply to employees and relevant contractors, temporary workers, and third parties who access company systems or information, according to their relationship with Solstice and contractual obligations. Specific legal and regulatory requirements should be confirmed through a separate applicability assessment; the scenario does not identify a definitive set of laws or certifications.

3. Policy Hierarchy

A useful hierarchy separates high-level direction from detailed requirements and work instructions:

Tier	Document type	Purpose	Example for Solstice
1	**Policy**	States management intent, principles, scope, and mandatory expectations.	Information Security Policy; Change Management Policy.
2	**Standard**	Defines specific mandatory technical or operational requirements that support a policy.	Approved authentication requirements; device encryption baseline; secure configuration standard.
3	**Procedure**	Explains the repeatable steps people must follow to perform a process.	Change request and approval procedure; user access provisioning procedure.
4	**Guideline**	Provides recommended practices or advice where flexibility is appropriate.	Remote-working security tips; examples of data handling practices.

Correction to the original hierarchy

In the submitted answer, Mobile Device Policy and Remote Access and VPN Policy were listed as “Policy + Standard.” For a clearer framework, treat each as a policy at Tier 1 and create separate supporting standards at Tier 2 where technical requirements are needed. A policy and a standard are related but are not the same document.

4. Recommended Policy Framework

The six policies below reflect the four foundational and two advanced policies selected in the original assignment, with clearer objectives and more appropriate ownership. Review frequencies are proposed internal governance cadences, not universal legal requirements.

Policy	Tier	Why it is needed	Suggested owner / approval	Review cadence
Information Security Policy	Policy	Sets the overall direction for protecting company information, systems, and services.	Owner: Security/GRC lead. Approval: Board or delegated executive authority.	Annually and after material change.
Access Control Policy	Policy	Defines how access is requested, approved, changed, reviewed, and removed.	Owner: IT/Security. Approval: designated executive authority under policy governance.	Annually; access rights reviewed on a defined risk-based schedule.
Data Classification and Handling Policy	Policy	Establishes classification levels and handling rules for patient wellness data, employee data, and business information.	Owner: Security/GRC with data owners. Approval: designated executive authority.	Annually and after major data or business changes.
Acceptable Use Policy	Policy	Defines acceptable use of company accounts, devices, applications, networks, and information.	Owner: IT/Security with People & Operations. Approval: designated executive authority.	Annually.
Mobile Device Policy	Policy	Sets expectations for company and permitted personal devices accessing company data; supports secure handling of mobile endpoints.	Owner: IT/Security. Approval: designated executive authority.	Annually and after significant technology changes.
Remote Access and VPN Policy	Policy	Defines secure remote access, authentication, device requirements, and authorization for remote workers and approved third parties.	Owner: IT/Security. Approval: designated executive authority.	Annually and after significant access changes.

5. Change Management Policy

Document status: Proposed policy for leadership review. **Version:** 1.0. **Policy owner:** IT Operations / Security, with GRC coordination. **Approver:** designated executive authority or a formally authorized Change Advisory Board (CAB), according to change risk and organizational delegation.

Purpose

The purpose of this policy is to ensure that changes to Solstice Health Analytics' information systems, cloud services, applications, configurations, integrations, and security controls are requested, assessed, authorized, implemented, and reviewed in a controlled and traceable manner. The policy aims to reduce service disruption, security weaknesses, data exposure, and unplanned operational impact.

Scope

This policy applies to employees and authorized contractors who request, assess, approve, implement, or review changes to production and other in-scope technology services, including Azure-hosted environments, the patient wellness analytics platform, wearable-device data integrations, telehealth partner connections, identity and access configurations, and security controls. Emergency changes are included but may follow an expedited process with retrospective review.

Three key policy statements based on the change lifecycle

1. Request: All planned changes must be recorded in an approved change-management system before work begins. The request must describe the change, business reason, affected systems and data, owner, expected timing, dependencies, implementation steps, testing plan, and rollback or recovery plan where feasible.

2. Assess and approve: Each change must be assessed for security, privacy, operational, availability, integration, and business impact, with risk and testing evidence documented. Changes must be approved by an authorized approver or CAB before implementation; requesters must not approve their own changes where separation of duties is practicable. Emergency changes may use an expedited approval path with documented justification.

3. Implement and review: Approved changes must be implemented by authorized personnel during an agreed change window, following the documented plan. The implementer or designated reviewer must verify outcomes, record test results and issues, confirm service stability, and complete a post-implementation review. Failed changes must be handled using the documented rollback or recovery plan, and the change record must be closed with evidence.

6. Approval and Review Lifecycle

Lifecycle stage	Required activity	Evidence to retain
Request	Log request, purpose, affected assets, owner, schedule, dependencies, and rollback plan.	Change ticket and supporting documentation.
Assess	Assess risk, security/privacy impact, testing, availability, dependencies, and business impact.	Risk/impact assessment and test plan.
Approve	Obtain authorization from the correct approver or CAB before implementation, except through documented emergency handling.	Approval record, conditions, and scheduled window.
Implement	Execute the approved plan, validate results, and use rollback/recovery steps if required.	Implementation log, test results, incident records if applicable.
Review	Confirm expected outcomes, capture lessons, resolve outstanding issues, and close the record.	Post-implementation review and completed change record.

7. Ownership, Communication, and Review

The original answer proposed that all employees report to the Chief Information Security Officer and introduced different in-office reporting days for each office. Those directions do not directly support a Change Management Policy and could create unnecessary operational disruption. This revised policy instead assigns policy ownership and change approval responsibilities while leaving organizational reporting lines and attendance arrangements to the appropriate HR and management policies.

Recommended governance arrangements

• **Policy owner:** IT Operations / Security, coordinating with the GRC function.
• **Approver:** Board or delegated executive authority for the policy; a CAB or authorized change approver for individual changes, based on documented delegation.
• **Review cadence:** Review the policy at least annually and after significant incidents, audit findings, major platform changes, or material changes to business or regulatory requirements.
• **Communication:** Publish the approved policy in a controlled repository and communicate it to affected employees and contractors.
• **Exceptions:** Document, risk-assess, approve, time-limit, and periodically review exceptions.

8. Findings and Improvements

The original submission made sensible policy selections and recognized the need for approval and periodic review. The key improvements in this assessment are:

• Clarified the distinction between policies, standards, procedures, and guidelines.
• Treated Mobile Device and Remote Access/VPN as policies, with supporting standards to be developed separately.
• Added policy owners and more practical approval responsibilities instead of assigning every policy to the board without delegation.
• Rewrote the Change Management Policy statements to cover request, assessment and approval, implementation, and post-implementation review.
• Removed unrelated reporting-line and office-attendance instructions from the change policy.
• Added evidence expectations so compliance can be demonstrated rather than assumed.

9. Conclusion

Solstice Health Analytics should establish a clear policy hierarchy and prioritize foundational security policies that address information protection, access, data classification, and acceptable use. Mobile device and remote access policies are also relevant to its cloud-based, remote-first environment. A controlled Change Management Policy will help ensure that system and security changes are authorized, assessed, documented, and reviewed. The proposed framework is a starting point and should be tailored through stakeholder review and an assessment of the company's actual legal, contractual, and security obligations.

10. Author

Project: Solstice Health Analytics Policy Framework Architecture
Specialization: Governance, Risk, and Compliance (GRC)
Focus areas: Policy Hierarchy, Policy Governance, Change Management, Approval and Review Lifecycle

---

Educational case study based on the supplied assignment scenario and submitted draft. This report is not a legal opinion, certification, or formal audit of an actual organization.